Production Readiness: Legal, Data and Operational Risks Review

Reviewed **28 October 2026** Scope **the proof of concept as it is today** **Not legal advice**

What could go wrong if this proof of concept is used in production, how likely it is to hurt, and what to do first. Reviewed on 28 October 2026 against the app as it is today. This is a technical review, not legal advice: get a legal sign-off for the website-terms and data-protection points.

VERDICT

No blockers

Open-source licenses

No blockers. All 196 packages, the font and the icons use permissive licenses; no GPL or AGPL code. Add one attribution file.

Needs work

Legal and data

Needs sign-off. Website terms, AI providers' data agreements and personal-data law must be cleared per use case.

Needs work

Architecture

Fine for one person on their own PC. A shared or server deployment needs sign-in, access control and HTTPS first.

THE RISKS AT A GLANCE

#	RISK	AREA	SEVERITY	FIRST ACTION
1	**Breaking websites' terms of use**	LEGAL	High	Get a legal review for every site you plan to collect from in production.
2	**Sending page content to outside AI providers**	DATA & CONTRACTS	High	Sign each provider's data processing agreement (DPA) and use their business / API terms, not consumer accounts.
3	**Personal data protection law**	LAW	Medium	Keep personal-data collection off unless there is an approved purpose.
4	**No login or access control**	SECURITY	High if shared	Keep it on localhost (one person, one PC) for now.
5	**The company's network getting blocked**	OPERATIONS	Medium	Keep the built-in throttling, cooldowns and never-solve-CAPTCHA rules.
6	**AI cost and quota surprises**	OPERATIONS	Medium	Use paid plans with spending limits set at the provider.
7	**Results that look right but aren't**	BUSINESS	Medium	Treat collected data as needing a check before it is used for decisions.

The risks in detail, most serious first

1 Breaking websites' terms of use

LEGAL — High

WHAT CAN HAPPEN

Large sites such as Booking.com and Amazon forbid robots, scrapers and automated data collection in their terms of use. Collecting from them commercially can lead to warning letters, blocked accounts or IP addresses, and claims for breach of contract. Some countries add database rights or anti-hacking laws on top.

WHY IT APPLIES HERE

The app follows robots.txt and refuses pages it disallows, but robots.txt is only a technical signal: a page being allowed there is not legal permission. The agent was tested on booking.com and planned for amazon.com, both of which forbid scraping in their terms.

WHAT TO DO

- Get a legal review for every site you plan to collect from in production.
- Use official data feeds where they exist (Booking.com Affiliate Partner programme, Amazon Product Advertising API).
- Keep the built-in safeguards on: robots.txt, rate limits, never solving CAPTCHAs, read-only actions.

2 Sending page content to outside AI providers

DATA & CONTRACTS — High

WHAT CAN HAPPEN

Page text, page summaries and HTML samples leave the company and are processed by OpenAI, Groq or Anthropic. If a page holds customer, employee or other personal or confidential data, that data is shared with a third party.

WHY IT APPLIES HERE

Planning, the agent's reasoning, column setup and the browser worker all call the AI model chosen in Settings → AI models. Personal data is masked before most calls, but page content is still sent.

WHAT TO DO

- Sign each provider's data processing agreement (DPA) and use their business / API terms, not consumer accounts.
- Write a rule for which sites and kinds of data may be collected with AI help.
- Keep personal-data masking on (the default).

3 Personal data protection law

LAW — Medium

WHAT CAN HAPPEN

Collecting names, phone numbers or e-mail addresses without a stated purpose, a retention limit and a way to delete them can breach India's Digital Personal Data Protection Act 2023, and the GDPR for data about people in the EU. Penalties under both are large.

WHY IT APPLIES HERE

Personal data is masked by default and can only be collected with an explicit opt-in and a purpose. The risk starts when someone switches that on.

WHAT TO DO

- Keep personal-data collection off unless there is an approved purpose.
- Write down the purpose, who may see the data, how long it is kept and how it is deleted.
- Use the app's delete actions to remove data that is no longer needed.

4 No login or access control

SECURITY — High if shared

WHAT CAN HAPPEN

Anyone who can reach the app can read every scraped result, use saved site logins, start agents that spend AI credit, and change the AI keys in use.

WHY IT APPLIES HERE

The app was built as a single-user tool on your own PC: it has no accounts or passwords and trusts every request. That is safe on localhost and unsafe on any shared network or server.

WHAT TO DO

- Keep it on localhost (one person, one PC) for now.
- Before any shared or server deployment, add sign-in, roles, HTTPS and an audit of who did what.

5 The company's network getting blocked

OPERATIONS — Medium

WHAT CAN HAPPEN

Big retail and travel sites detect automation. Repeated runs from the office connection can get the office IP address blocked or flagged, which affects everyone there, not only this tool.

WHY IT APPLIES HERE

Booking.com already serves automated browsers a different flow, and Amazon often answers automated visits with a robot check.

WHAT TO DO

- Keep the built-in throttling, cooldowns and never-solve-CAPTCHA rules.
- Avoid high volumes or tight schedules against large commercial sites.

6 AI cost and quota surprises

OPERATIONS — Medium

WHAT CAN HAPPEN

One agent run uses roughly 30,000 to 100,000 AI tokens. Free tiers run out after a few runs a day; paid usage grows quickly with more users or scheduled runs.

WHY IT APPLIES HERE

Groq's free daily limit was used up during testing after a handful of runs. Each run has step, time and AI-call limits, but there is no monthly budget.

WHAT TO DO

- Use paid plans with spending limits set at the provider.
- Keep the per-run limits, and choose a reliable main model (for example gpt-5-mini) with a backup.

7 Results that look right but aren't

BUSINESS — Medium

WHAT CAN HAPPEN

Sites change layout, A/B-test pages and show different pages to automated browsers. A run can finish "successfully" with missing or wrong columns, and decisions made on that data would be wrong.

WHY IT APPLIES HERE

This happened in testing: one booking.com run first collected the right 15 hotels, then an automatic fix replaced them with 10 rows with empty names and prices. That fix logic has since been corrected, but the risk remains in general.

WHAT TO DO

- Treat collected data as needing a check before it is used for decisions.
- Read each result's Quality tab and warnings; re-run or re-record when columns come out empty.

8. Open-source licenses No blockers

The license data of all 88 packages in the app's environment and all 108 in the browser worker's environment was read, plus the bundled scripts, font and icons. Everything is permissive (MIT, BSD, Apache 2.0, MPL 2.0 used unmodified, SIL OFL for the font). There is no copyleft code that would force the source to be published, even if the tool is sold or offered as a service.

PART	PACKAGES	LICENSE
Web app	FastAPI, Starlette, Uvicorn, Jinja2, Pydantic	MIT / BSD-3
Fetching and parsing	httpx, requests, selectolax, BeautifulSoup, lxml	BSD / MIT / Apache-2.0
Results and export	pandas, numpy, openpyxl	BSD-3 / MIT
Encryption	cryptography	Apache-2.0 or BSD-3
Browser rendering	Playwright (and its Chromium)	Apache-2.0 (Chromium BSD-style)
Agent browser	browser-use, cdp-use, bubus, browser-use-sdk	MIT (telemetry and cloud sync switched off)
AI provider SDKs	openai, anthropic, groq, google-genai	Apache-2.0 / MIT
Certificates, progress bars	certifi, tqdm	MPL-2.0 (fine when used unmodified)
Front end	Alpine.js 3.14.1, Tailwind CSS	MIT (attribution notice to add)
Font and icons	Roboto, Material Symbols	SIL OFL 1.1 / Apache-2.0

Paperwork to finish: MIT requires the copyright notice to travel with every copy. The bundled Alpine.js file and the compiled Tailwind CSS (which embeds Tailwind's Preflight base styles) ship without it, so add a THIRD_PARTY_NOTICES file with their MIT notices, the Apache-2.0 notice for Material Symbols and a pointer to the Roboto license. Also decide who owns the project's own code (normally the employer); it has no LICENSE file yet.

9. Before going to production

- [ ] **Legal:** Legal review of the terms of use of every site to be collected from; official APIs where they exist.
- [ ] **Contracts:** Data processing agreements and business plans with the AI providers in use, with spending limits.
- [ ] **Data:** Written purpose, access, retention and deletion rules; personal-data collection stays off by default.
- [ ] **Security:** Stay on localhost, or add sign-in, roles, HTTPS and an audit trail before sharing the app.
- [ ] **Operations:** Agree run volumes per site; keep throttling, cooldowns and the never-solve-CAPTCHA rule.
- [ ] **Quality:** A person checks the Quality tab before collected data is used for decisions.
- [ ] **Paperwork:** Add the THIRD_PARTY_NOTICES file and decide the project's own license and owner.

Sources: installed package metadata in .venv and .venv-agent, the bundled front-end files, the app's own safeguards and the agent test runs of 26-27 October 2026. Not legal advice.